

Evaluación del informe técnico preliminar

Análisis de los seis hallazgos presentados y del nivel de evidencia necesario para validarlos.

El informe identifica riesgos que merecen revisión, pero varias afirmaciones parecen desactualizadas o demasiado categóricas. Antes de convertirlas en un plan de trabajo, conviene exigir evidencia concreta: archivo, ruta, flujo probado, resultado reproducible y consecuencia técnica.

1 Seguridad del repositorio

POTENCIALMENTE CRÍTICO

Si el repositorio realmente es público y contiene una clave secreta activa, este es el punto más urgente.

- No basta con volver privado el repositorio: la clave debe revocarse y renovarse, porque seguirá existiendo en el historial de Git.
- La empresa debería indicar qué servicio está afectado, dónde apareció la clave y si comprobó que la credencial funciona.
- También debe distinguirse una clave pública de cliente —por ejemplo, una *publishable key*— de una clave secreta. No toda cadena denominada “key” constituye una filtración.

2 Carga de contenido

PARECE INCORRECTO O DESACTUALIZADO

RESONANCIA ya cuenta con catálogo remoto y flujos administrativos para crear y editar contenido. El servidor admite sesiones provenientes de la base de datos y la aplicación recibe actualizaciones del catálogo.

Puede haber campos o tipos de contenido que todavía requieran intervención técnica, pero afirmar que **toda sesión nueva exige editar código y recompilar** no parece reflejar el estado actual.

La empresa debería demostrar qué operación intentó realizar desde el panel y exactamente dónde quedó bloqueada.

3 Audio dentro de la aplicación

PARCIALMENTE CIERTO

Existen recursos incluidos en la aplicación, pero también infraestructura para audio remoto y almacenamiento. Por eso, afirmar que “todas las pistas van en el instalador” parece una generalización.

- La recomendación de distribuir el contenido editorial desde la nube es correcta.
- Debe identificarse qué audios siguen empaquetados, cuáles son remotos y si los locales son recursos esenciales o contenido heredado.
- También corresponde evaluar caché, descargas incompletas, URLs firmadas, reproducción sin conexión y protección del contenido privado.

4 Motor de reproducción

OBSERVACIÓN VÁLIDA, PERO SUPERFICIAL

Existen diferentes rutas de audio porque la aplicación resuelve necesidades distintas: sesiones, reproducción continua, mezclas sincronizadas, chat y funcionamiento con la pantalla bloqueada.

Tener varias tecnologías no constituye por sí solo un defecto. El riesgo está en su coordinación: interrupciones, reproducción simultánea, llamadas, auriculares, segundo plano, bloqueo de pantalla y cambios de sesión.

Es razonable convertir el audio en un foco fuerte de pruebas sobre dispositivos reales, especialmente iPhone. Sin embargo, el informe debería especificar qué “avisos” encontró y si corresponden a comentarios históricos, tareas pendientes o fallos reproducibles.

5 Suscripción premium

NECESITA DEMOSTRACIÓN TÉCNICA

Si el acceso solamente se oculta desde la interfaz, sería un problema grave. La afirmación debe comprobarse intentando acceder directamente a endpoints, archivos privados o contenido premium mediante un usuario sin derechos.

La protección adecuada debe incluir varias capas:

- Autorización del lado servidor.
- Verificación vigente de la suscripción.
- Control de acceso a los objetos privados.
- URLs firmadas de corta duración.
- La interfaz como capa adicional, no como única barrera.

Este punto merece una auditoría específica, pero no debería aceptarse como confirmado sin una prueba reproducible.

6 Publicación y plataforma

PARECE EXAGERADO

La aplicación ya tiene configuración móvil y antecedentes de compilación nativa. Decir que la configuración para tiendas “no está inicializada” probablemente está desactualizado.

Sí es razonable discutir dónde residirán a largo plazo el backend, la base de datos, los objetos y la observabilidad. Sin embargo, “depende por completo de Replit” no constituye por sí mismo un hallazgo técnico suficiente.

La evaluación debería separar:

- Los componentes efectivamente acoplados a Replit.
- Los servicios que son portables.
- El costo y la complejidad de una eventual migración.
- La necesidad real de migrar.

Depender de una plataforma no es automáticamente un problema; lo relevante es el nivel de bloqueo y la existencia de un plan de continuidad.

Documento de evaluación preparado para discusión técnica. No sustituye una auditoría de seguridad ni pruebas directas sobre los entornos de desarrollo y producción.